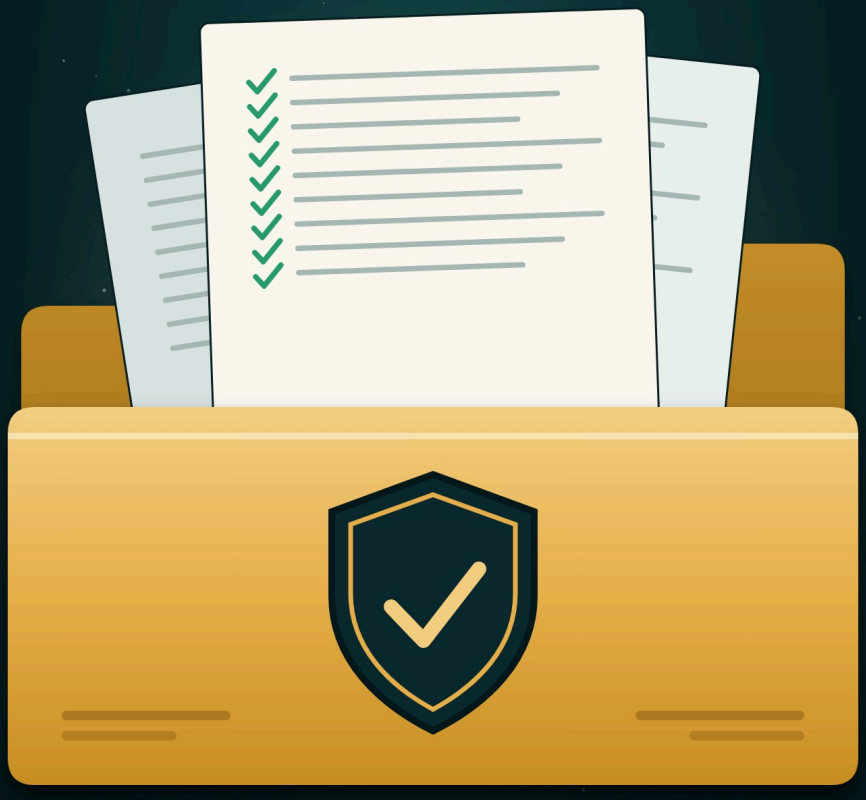
CYBER INSURANCE READINESS

THE CYBER CLAIM FILE



What Small Businesses Should **Document** Before, During and After a **Cyber Incident**

EVIDENCE | TIMELINES | POLICY CONDITIONS | LOSS RECORDS

ZIRLANDIA MILKOVIC

CYBER INSURANCE READINESS

THE CYBER CLAIM FILE

What Small Businesses Should Document Before, During and After a Cyber Incident

ZIRLANDIA MILKOVIC

The Cyber Claim File
What Small Businesses Should Document Before, During and After a Cyber Incident

© 2026 Zirlandia Milkovic. All rights reserved. No part of this book may be reproduced without written permission, except for brief quotations in reviews.

First edition, 2026. Research cut-off: 12 November 2026. British English. Companion resource: GDPRGard.eu. Cover and diagrams created by the author with design tools; some illustrations were generated with AI image tools.

This book is practical guidance, not legal, security or data-protection advice. All examples, businesses and people in worked scenarios are fictional. Policy and legal references reflect the research cut-off date and should be checked against current texts.

Contents

START HERE

Educational Disclaimer 4
Introduction: The Folder Nobody Opened 4
Who This Book Is For 6
How to Use This Book 6
The Ten-Minute Claim-Readiness Check 7

CHAPTERS

1. Understanding Cyber Insurance Documentation 9
2. Before an Incident: Building Your Claim-Ready File 15
3. During an Incident: Evidence and the Incident Timeline 21
4. Notifying the Insurer and Meeting Policy Conditions 28
5. Business Interruption and Financial Loss Records 35
6. Working with Forensic, Legal and Other Specialists 40
7. After the Incident: Assembling and Submitting the Claim 45
8. Common Documentation Mistakes 50

CLOSING

Conclusion: Show Your Working 53

APPENDICES

Appendix A: Policy Conditions Checklist 54
Appendix B: Pre-Incident Readiness Record 56
Appendix C: Incident Timeline and Decision Log 57
Appendix D: Evidence and Chain-of-Custody Log 58
Appendix E: Insurer Notification Record and Letter 59
Appendix F: Business Interruption Loss Worksheet 61
Appendix G: Specialist and Cost Log 63
Appendix H: Claim Pack Index 64

BACK MATTER

Glossary 65
A Note on GDPRGard.eu 66
About the Author 67
Notes and Sources 68

Educational Disclaimer

This book is practical, educational guidance for small-business owners, freelancers, office managers and the consultants who support them. It is not legal, insurance, financial, accounting or security-engineering advice, and it does not create a professional relationship between the author and the reader.

Cyber insurance policies differ enormously. Wording, definitions, exclusions, limits, notification deadlines and claims procedures vary between insurers, between products and between countries, and the law that governs your policy decides what happens in a dispute. **Your policy wording, and the advice of your broker, your insurer's claims team and a qualified lawyer, always come first.** Nothing here changes what your policy says.

Following the habits in this book can make a claim better organised, faster to assess and harder to dispute. It cannot guarantee that a claim is accepted or paid, and it is never a reason to delay telling your insurer about an incident.

Every business, person and incident in a worked example is **fictional** and labelled as such. Real laws, cases and standards are sourced in the notes at the back, together with an honest list of what the author could not verify.

Introduction: The Folder Nobody Opened

Halden & Roe is a six-person accountancy. On a Tuesday morning in March every file server screen shows the same message, and nobody can open a client file. Within the hour the office manager, Ines, has done what most of us would do: she has rung the IT freelancer, switched off two computers, and started to write down what she remembers.

By lunchtime the practice has a plan, a ransom demand, a worried partner and a cyber insurance policy that nobody has read since the day it was bought. The policy says something about a 24-hour hotline. Ines finds the number in an email from eleven months ago. Meanwhile the freelancer has already started rebuilding one server, and a recovery specialist recommended by a friend has been asked to start the next morning.

Three weeks later the claim is in trouble. Not because the policy excluded ransomware, it did not, but because of the **paperwork**. The insurer was called late in the afternoon, not in the first hour. The specialist was not on the insurer's panel and nobody asked permission. The rebuilt server was wiped before an image was taken. The timeline is Ines's memory. The lost fees are a guess. The application form, filled in a year ago, said multi-factor authentication was used "on all remote access" and nobody can now prove which accounts that covered.

Halden & Roe is fictional. The pattern is not. Insurers, brokers and lawyers who handle cyber claims describe the same problems again and again: late notice, spending without consent, destroyed evidence, unclear timelines and loss figures that cannot be supported.[1][2] None of these is a technical failure. They are **documentation failures**, and they are almost entirely preventable.

This book is about that. It does not teach you how to defend a network or negotiate a policy. It teaches you what to **write down, keep and hand over**: before an incident, so that the evidence exists; during one, so that it is preserved; and after one, so that the claim is complete and credible. It calls the result **the claim file**.

You will not be asked to become a forensic examiner or an accountant. You will be asked to build a few simple habits and fill in a few simple records, most of which are in the appendices and can be photocopied or retyped on Monday morning.

> **The rule.** A cyber claim is not decided by how bad the incident was. It is decided by what you can show, and when you told your insurer.

The book follows the life of a claim. Chapter 1 explains what a cyber policy is and what insurers will ask for. Chapter 2 builds your claim file **before** anything goes wrong. Chapter 3 covers the first hours: evidence and the incident timeline. Chapter 4 covers telling your insurer and meeting policy conditions. Chapter 5 deals with business interruption and financial loss records. Chapter 6 shows how to work with forensic, legal and other specialists. Chapter 7 covers assembling and submitting the claim. Chapter 8 lists the common mistakes and how to avoid each one. The appendices hold the logs, worksheets and letters.

Who This Book Is For

This book is written for people who run or look after a small business but are not insurance or security specialists:

- **Owners and managers of small businesses**, roughly one to fifty people, who hold or are considering a cyber insurance policy.
- **Freelancers and consultants** whose whole income depends on a laptop and a handful of online services.
- **Office managers and operations leads**, the "accidental IT person" who will be the one on the phone when something goes wrong.
- **Advisers**, such as accountants, IT freelancers, consultants and brokers' clients' contacts, who are asked "what should we keep?"
- **Anyone preparing for a renewal**, who wants to show an underwriter that the business is organised.

It is written in British English, with examples in euros, and it is not specific to one country. Where a rule is European, it says so. Where practice differs by country or by policy, it says that too, and points you to your policy and your adviser.

It is **not** written for large organisations with a legal department, a risk manager and a claims team, although they may find the checklists useful. It also does not replace the incident-response plan or the security measures that reduce the chance of a claim in the first place.

How to Use This Book

You can read the book front to back in an evening, but it is designed to be used in three ways.

Before an incident (today). Read Chapters 1 and 2, then work through Appendices A and B. These give you a *policy conditions checklist* and a *readiness record*. It is a few hours of work and it is the single most valuable thing in the book.

During an incident (in the first hours). Go straight to Chapters 3 and 4 and Appendices C, D and E. They give you the first-hour sequence, a timeline log, an evidence and chain-of-custody log and a notification record. Print them and keep a copy somewhere that does not depend on your computers working.

After an incident (in the weeks that follow). Chapters 5 to 7 and Appendices F, G and H cover the loss worksheet, the specialist and cost log and the claim pack index.

Look for four recurring features:

- **The rule** boxes are the one idea to remember from each chapter.
- **Worked examples** follow two fictional businesses, *Halden & Roe*, a six-person accountancy hit by ransomware, and *Brightline Print*, a nine-person print shop that paid a fake invoice.
- **Figures** are diagrams and photographs that summarise a chapter's idea in a form you can pin to a wall.
- **Checklists** have a box for each step. Tick them, date them and keep them: a completed checklist is itself a record.

A practical note. Wherever this book tells you to keep something, keep it **in more than one place**, and at least one copy **outside the systems an attacker could reach**: a printed folder, an encrypted external drive kept off-site, or a document store that does not use your main login. A claim file that is locked by the same ransomware as everything else is not much use.

The Ten-Minute Claim-Readiness Check

Answer honestly. Tick what is true **today**, and be able to show it.

- ☐ I can find our cyber insurance policy, endorsements and schedule in under five minutes, on paper or off-network.
- ☐ I know the insurer's 24-hour incident hotline number and it is saved somewhere other than our email.
- ☐ I have a copy of the application or proposal form we completed, and I know what it said about our security controls.
- ☐ I know the notification clause: who to tell, how, and by when.
- ☐ I know whether we must use the insurer's panel vendors or get consent before spending money.
- ☐ I know our excess (retention), waiting period and indemnity period for business interruption.
- ☐ Someone named in writing owns the claim file and the first call.
- ☐ We keep an up-to-date list of our systems, services and where our data is.
- ☐ We can show dated proof of our key security controls (for example multi-factor authentication, backups, updates).
- ☐ We have the last 12 to 36 months of monthly sales and profit figures to hand for a loss calculation.
- ☐ A printed copy of our incident contacts and logs is stored outside our network.
- ☐ We know what to do in the first hour, and what **not** to do.

Scoring. 10 to 12 ticks: you are claim-ready; use the book to polish. 6 to 9: you have the bones; focus on Chapter 2. 0 to 5: do Appendix A and the hotline step today, then read on. Whatever your score, repeat the check after you finish the book.

CHAPTER 1

Understanding Cyber Insurance Documentation

CHAPTER 1
UNDERSTANDING CYBER INSURANCE DOCUMENTATION

A thick case folder under a desk lamp: the claim file starts long before the claim

Most small businesses buy cyber insurance the way they buy a fire extinguisher: once, with a quick glance at the price, and with the hope of never touching it. That is understandable. It is also the root of most claim problems, because a cyber policy is not a magic shield that responds to bad events. It is a **contract with conditions**, and a claim is a **request that you prove you met them**.

Documentation is how you prove it. This chapter explains what a cyber policy typically contains, which documents sit around it, and what an insurer is really asking when it asks you for "supporting information".

What a cyber policy usually covers

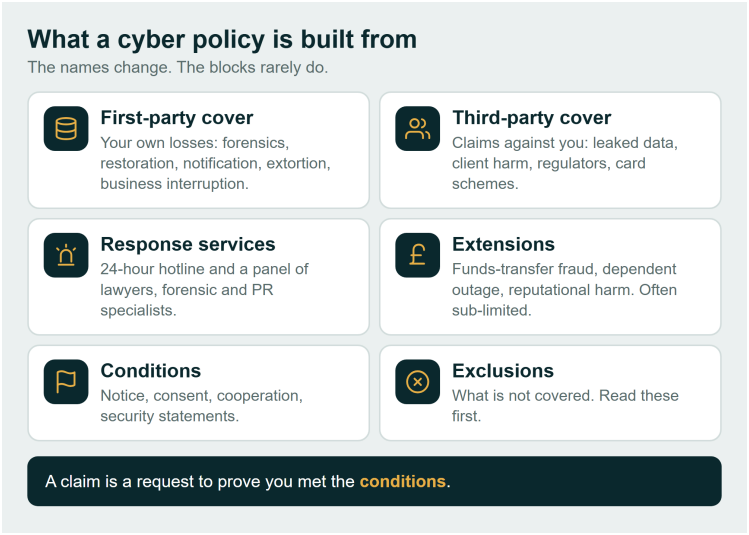
Wordings differ, but most cyber policies for small businesses are built from the same blocks.[3]

First-party cover pays for your own losses and response costs. This commonly includes forensic investigation, legal advice, notifying customers and regulators, restoring data and systems, cyber extortion, and **business interruption**: the income you lose while systems are down.

Third-party cover responds when someone else says you harmed them: a customer whose data leaked, a client who suffered because your systems were down, a payment-card scheme or a regulator. It can include defence costs and, where the law allows, damages or settlements.

Incident-response services are often the most valuable part for a small firm: a 24-hour hotline and a panel of lawyers, forensic specialists and communications advisers that the insurer has already contracted. You may never see a cheque, but you will see these experts.

Optional extensions vary: funds-transfer fraud or social engineering, dependent business interruption (loss caused by a supplier's outage), reputational harm, and bricking of hardware. These are very often **sub-limited**, meaning capped well below the main limit.



The usual building blocks of a small-business cyber policy

The words that decide a claim

You do not need to be an insurance lawyer, but a handful of terms appear in almost every dispute. Find each one in your own policy and write the answer in Appendix A.

Term	What it means in plain English	Why it matters for documents
Limit	The most the insurer will pay, per claim or per year.	Costs count towards it, so track every one.
Sub-limit	A lower cap for one type of loss, such as fraud or extortion.	Your largest loss may sit under a small cap.
Retention or excess	The amount you bear before the insurer pays.	You must still prove the loss exceeds it.
Waiting period	The first hours of downtime, often 8 to 24, that are not covered.	You need to show exactly when downtime began and ended.
Indemnity period	How long after the incident the insurer will pay for lost income.	Your loss records must cover the whole period.
Notification condition	When and how you must tell the insurer.	Late or wrong notice can jeopardise cover.
Consent / panel	Whether you must use the insurer's vendors or ask before spending.	Unapproved costs may not be repaid.
Exclusions	Events or losses the policy does not cover.	Your evidence may decide which side of the line you are on.
Warranties or minimum security conditions	Controls you said you have, such as MFA or backups.	You may need to prove they existed, with dates.

The rule. If you cannot explain, in one sentence each, your excess, waiting period, indemnity period and notification duty, you are not yet claim-ready. Chapter 2 and Appendix A fix that.

Claims-made, discovery and "notice of circumstances"

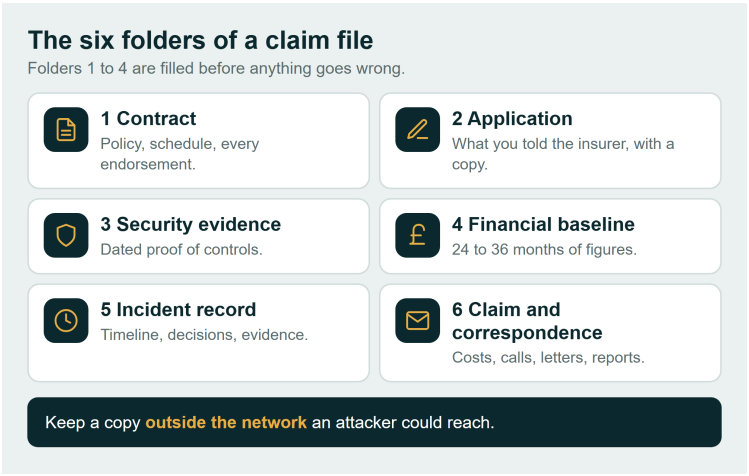
Many cyber policies work on a **claims-made and reported** basis, or on a **discovery** basis: the event must be discovered or the claim made within the policy period, and reported to the insurer within the policy period or a short extension. The practical lesson is simple. If you discover something suspicious near renewal, **tell the insurer promptly**

and ask about a *notice of circumstances*. Waiting to see whether it "turns into something" can leave you with an uninsured problem and a renewal application that must now disclose it.

The documents that surround a policy

A policy is rarely a single PDF. When a claim arrives, an insurer may look at five groups of documents, and you should know where each one is.

1. **The contract:** the policy wording, the schedule of limits and excesses, and every endorsement. Endorsements change the wording and are easy to lose.
2. **The application:** the proposal form, questionnaire or online application, and any emails with the broker. This is what you *told* the insurer.
3. **Your security evidence:** proof that the controls you described existed and worked, with dates.
4. **Your financial baseline:** the figures that let someone calculate what you lost.
5. **The incident record:** everything created from the moment you notice something wrong.



The six folders of a claim file, and when each one is filled

The application is a document too

The second group deserves a warning. Underwriters rely on what you say when you buy cover. If a statement turns out to be materially wrong, an insurer may refuse a claim or, in some legal systems, seek to cancel the policy from the start. A well-known US example is *Travelers v. International Control Services* (2022), in which an insurer sued to rescind a policy after a ransomware attack, alleging the company overstated its use of multi-factor authentication in the application; the case ended with a court-approved rescission, though the details of the dispute are contested and the law differs in each country.[6]

You do not need to remember the case. You need the habit: **keep a copy of what you submitted, keep dated proof for every security statement in it, and update the insurer or broker if reality changes** (for example, if you stop using a tool you said you had).

What an insurer will ask for

When you report a claim, expect questions in five families. This is the real purpose of everything that follows in the book.

- **What happened?** A clear sequence of events with times, and how it was discovered.
- **How did it happen?** The route in, the systems involved, what was affected. Often a forensic report.
- **Did you meet the conditions?** When you told them, whether you got consent, whether the controls in your application were in place.
- **What did it cost?** Receipts, invoices, quotes, time records, lost-income calculations.
- **What did you do to limit the loss?** Evidence that you acted sensibly and promptly.

> **Worked example (fictional): Brightline Print.** Brightline, a nine-person print shop, pays an invoice for 18,400 euros after an email appears to come from its paper supplier with "new bank details". The mistake is discovered four days later. Its policy has a 25,000 euro sub-limit for social-engineering fraud and a condition that any bank-detail change must be confirmed by phone to a known number. The first question from the insurer is not "how much?" It is "show us the confirmation call record." Brightline has none.

What this book will and will not do

It will help you create and keep the documents above. It will not tell you which policy to buy, whether a particular loss is covered or how to argue a coverage dispute. Those questions belong to your broker, your insurer and your lawyer. The best thing you can do for any of them is hand over an organised file.

The claim file across the life of an incident

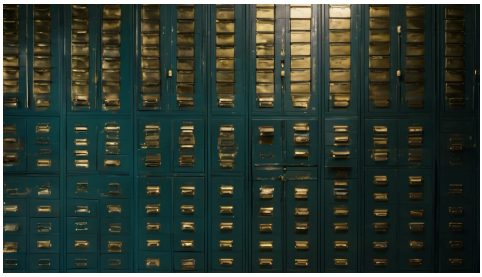
Chapter checklist

- ☐ I have found my policy, schedule and every endorsement, and stored a copy off-network.
- ☐ I have filled in the key terms in Appendix A (limit, excess, waiting period, indemnity period, notification, consent).
- ☐ I have a copy of the application and I have flagged every security statement in it.
- ☐ I know which five groups of documents I hold and which I am missing.

CHAPTER 2

Before an Incident: Building Your Claim-Ready File

CHAPTER 2
BEFORE AN INCIDENT: THE CLAIM-READY FILE



An archive of steel cabinets with one drawer open: records you can reach when you need them

The cheapest time to prepare a claim is when you do not have one. Before an incident you have time, working systems and calm people. During one you have none of those. This chapter builds the file in eight steps, each of which takes an hour or two. Appendix B records the result.

Step 1: Name an owner and a deputy

A claim needs one person who is accountable for it, and another who can step in. Write down both names, their phone numbers and what each is authorised to do. Authority matters: in the first hours someone must be able to say "call the insurer, isolate the network and agree to a specialist" without waiting for a partner who is on holiday.

Decide in advance **who may spend money**, up to what amount, and who must approve more. Insurers often want to approve costs first; your own people should know that rule too.

Step 2: Store the contract and the hotline outside your network

Make three copies of the policy, schedule, endorsements and the application: one in your document system, one printed in a folder, one encrypted on a drive kept off-site or in a store that does not share your main login. Add a single page at the front of the folder with:

- the insurer's name, policy number and policy period;
- the **24-hour incident hotline** and the claims email;
- your broker's name and mobile number;
- the notification clause in your own words, with the page reference;
- your excess, waiting period and indemnity period.

Ransomware attackers know that victims keep their insurance documents on the machines they encrypt. Do not make their job easier.

Step 3: Make a simple map of what you have

You cannot describe a loss if you cannot describe what you own. Keep a list, updated every quarter, of:

- **Systems and devices:** servers, laptops, phones, network equipment, with owner and location.
- **Services and accounts:** email, accounting, CRM, shop, payment, website, file storage, and who administers each.
- **Data:** where customer, staff and financial data lives, and which of it is personal data.
- **Dependencies:** suppliers and cloud providers whose outage would stop you.
- **Backups:** what is backed up, where, how often, and who can restore it.

This does not need special software. A table is enough. In a claim it answers "what was affected?" and in a data-protection report it answers "what data was involved?"[4]

Step 4: Capture dated proof of your security controls

Most applications ask about a handful of controls: multi-factor authentication, patching, endpoint protection, backups, staff training, email filtering. For each control you claim, keep **dated evidence**:

Control	Evidence to keep	Refresh
Multi-factor authentication	Screenshot or export showing which accounts require it, including admins and remote access	Quarterly
Backups	Backup job reports; a log of the last test restore	Monthly
Patching and updates	Update reports or a dated patch log	Monthly
Endpoint protection	Console export showing devices covered	Quarterly
Staff training	Attendance list or completion records	After each session
Access reviews	A signed list of who has admin rights	Twice a year

Be precise, not optimistic. "MFA on all remote access" is a statement a claims team can test. If it is true for 18 of 20 accounts, write **18 of 20**, and fix the other two. The aim is not a perfect record. It is an *accurate* one.

Step 5: Build your financial baseline for loss calculations

Business interruption claims are won or lost on the numbers you had **before** the incident. Gather, and store off-network:

- monthly profit and loss accounts for the last **24 to 36 months** (at least 12);
- monthly sales or revenue by product or service line;
- your gross profit margin and a list of costs that continue when you are not trading, such as rent, salaries and loan repayments;
- a note of seasonality: busy months, quiet months, big annual contracts;
- the next 12 months' budget or forecast if you have one;
- order books, bookings or pipeline reports that show demand.

Refresh this pack every quarter. Chapter 5 shows how it is used.

Step 6: Write a one-page first-hour sequence

Your incident plan does not need 40 pages. It needs one page that a stressed person can follow. Chapter 3 gives a model. The key lines are: *contain without destroying evidence*; *call the hotline*; *start the timeline*; *do not pay, delete or negotiate alone*. Print it and put it at the front of the folder.

Step 7: Pre-arrange the logs and evidence settings

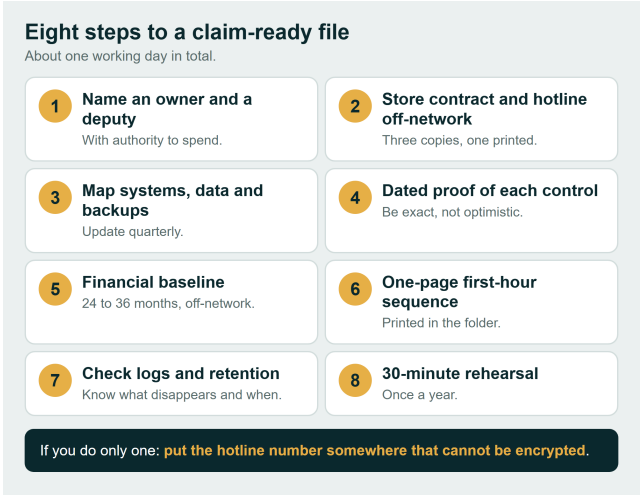
Many records disappear on their own. Cloud audit logs, firewall logs, email logs and security-tool alerts are often kept for a limited time, and some are off by default. In a quiet week, check, with your IT provider:

- which logs exist for email, file sharing, firewall, remote access and endpoint protection;
- how long each is kept and where;
- whether logs are copied somewhere an attacker cannot easily delete them;
- who has the rights to export them quickly.

Write the answers in Appendix B. If key logs are kept for only a few days, ask whether that can safely be extended. A timeline built on logs is far stronger than one built on memory.

Step 8: Hold a 30-minute rehearsal

Once a year, sit down for half an hour and walk through a pretend incident: *"It is Friday, 16:40. Every file is encrypted."* Who calls whom? Where is the hotline number? Who can approve spending? Where is the timeline log? Write down every point where someone says "I'm not sure", and fix those first.



Eight steps to a claim-ready file, and how often each is refreshed

Worked example (fictional): Halden & Roe, version two. After a near miss, Ines creates the folder. The front page holds the hotline, the broker's mobile, the excess of 2,500 euros, a 12-hour waiting period and a 60-day indemnity period. Behind it are the application, a quarterly MFA export, the last restore test and 36 months of monthly fees. The whole exercise takes her one working day, and her partners sign off on who can approve what. Six months later, when a phishing attack leads to a mailbox takeover, the first call goes out within twenty minutes.

The rule. Prepare the claim file as if you will need it on the worst day of the year, because you will need it on a day when your systems are not available.

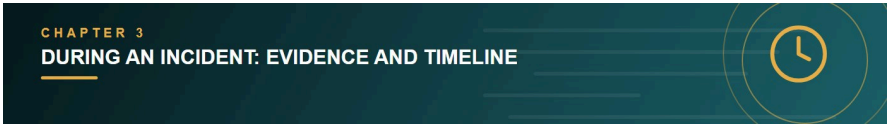
Chapter checklist

- ☐ Owner and deputy named, with authority to spend written down.
- ☐ Policy, application, endorsements and hotline stored in three places, one off-network.
- ☐ Systems, services, data and backups listed.
- ☐ Dated proof held for each security control stated in the application.
- ☐ 24 to 36 months of financial baseline stored off-network.
- ☐ One-page first-hour sequence printed.

- ☐ Log sources and retention checked and written down.
- ☐ A 30-minute rehearsal booked in the diary.

CHAPTER 3

During an Incident: Evidence and the Incident Timeline



A dark office at night and a single warning light: the first hours set the quality of the whole file

When an incident hits, the instinct is to fix it. Restart the server, delete the strange email, reset every password, wipe the infected laptop. Each of those actions is understandable, and each can destroy the evidence your claim, your lawyer and your regulator will need. This chapter gives you a calm order of operations and two records to keep throughout: **the timeline** and **the evidence log**.

The first hour in eight steps

The exact sequence depends on the incident, your policy and your specialists' advice. As a default for a small business:

1. **Stop and note the time.** Write down when you noticed the problem, who noticed it and what they saw. Do not tidy it up later.
2. **Contain without wiping.** Disconnect affected devices from the network (unplug the cable, turn off Wi-Fi) so the problem stops spreading. Do **not** reinstall, reset, delete or "clean" anything yet. Whether to power a machine off is a technical question: ask the insurer's incident line or your specialist, because powering down can lose evidence held in memory.

3. **Call the insurer's hotline.** Before engaging anyone else, if you can. Chapter 4 covers this.
4. **Open the timeline log and the decision log.** Appendix C. One person writes; others report to them.
5. **Capture what is visible.** Photograph or screenshot ransom notes, error messages, odd emails and login alerts, with the time. Take photos of screens with a phone if the computer is unusable.
6. **Preserve, do not forward.** Keep suspicious emails in their original form. If you must share them, forward as an attachment so the headers survive.
7. **Secure other accounts.** From a clean device, change passwords and sign out sessions for key accounts, but record exactly what you changed and when. Note anything you could not do.
8. **Do not pay, negotiate or delete.** Never pay a ransom, speak to an attacker or delete files until the insurer and your advisers have been involved. Payments can raise legal issues, including sanctions rules, and they are usually subject to the insurer's consent.

The first hour: do these in order

The rule. In the first hour, your job is not to fix the problem. It is to stop it spreading, call for help and keep the evidence intact.

The incident timeline

A timeline is the single most useful document in a cyber claim. It supports the insurer's assessment, your lawyer's regulatory notification, the forensic examiner's analysis and your own memory. It should be started in the first hour and kept until the claim is closed.

Each entry has six parts:

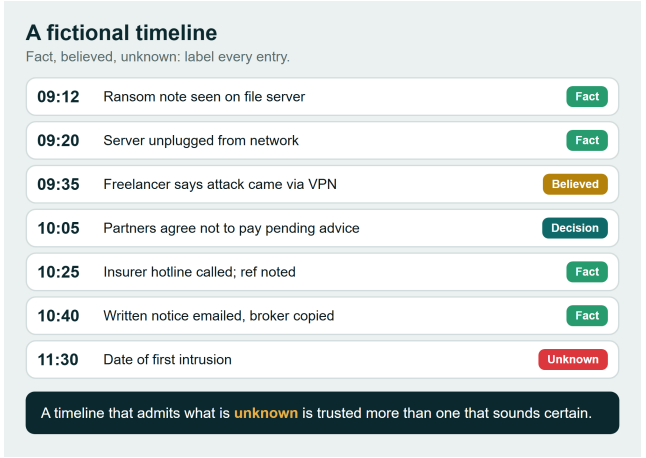
Part	What to write	Example
Date and time	Local time and time zone, to the minute	14 Mar 09:12 CET
What happened	A neutral, factual description	Office manager sees ransom note on file-server screen
Source	Who saw it, or which log says so	Ines Roe, in person
Status	**Fact**, **Believed** or **Unknown**	Fact
Action taken	Anything done in response, and by whom	Server unplugged from network, 09:20
Evidence reference	The ID in the evidence log	E-001 (photo of screen)

Three habits keep a timeline credible.

Separate fact from belief. "The attacker came in through the VPN" is a belief until a log or a specialist confirms it. Label it. Insurers and regulators trust timelines that admit what is unknown far more than ones that sound certain and are later contradicted.

Record decisions, not just events. A decision log, a column or a separate page, notes *what was decided*, *by whom*, *when and why*: "10:05, partners agree not to pay ransom pending insurer advice; Martin Halden". Months later, "why did you...?" is a common question.

Use one clock. Choose a time zone, state it, and note when machines show a different time. Logs are often in UTC; people think in local time. A one-hour error can make a sensible response look like a delay.

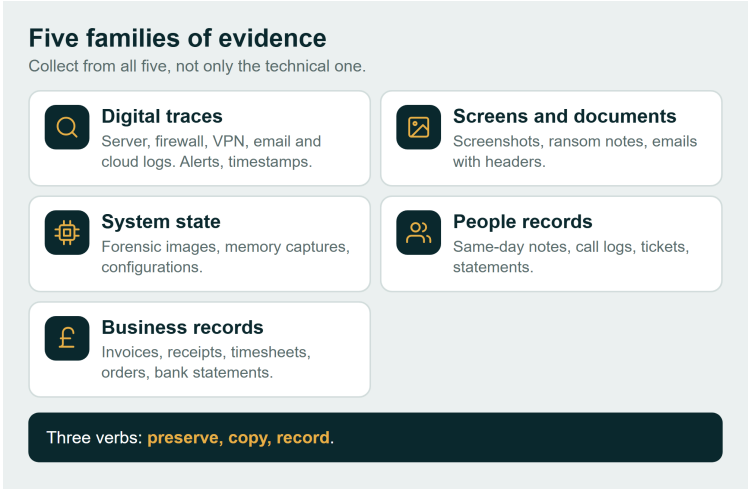


A fictional ransomware timeline, from first symptom to first call

What counts as evidence

In a claim, evidence is anything that helps show what happened, how, when and at what cost. It is useful to think in five families.

- **Digital traces:** server, firewall, VPN, email and cloud audit logs; endpoint-security alerts; file timestamps; malware samples; network captures.
- **Screens and documents:** screenshots, photos of ransom notes, emails with full headers, chat messages, tickets raised.
- **Systems state:** disk images and memory captures taken by a specialist; configuration files; backup catalogues.
- **People records:** who did what and when: notes, call logs, statements written the same day.
- **Business and financial records:** invoices, receipts, timesheets, orders, sales records, bank statements.



Five families of evidence in a cyber claim

Keeping evidence safe: preserve, copy, record

Three verbs cover most of what a small business needs to do.

Preserve. Leave affected machines as they are unless a specialist tells you otherwise. If something must be changed to restore service, take a forensic image first, or ask whether a specialist can, and note what was altered. Switch on or extend log retention where you can. Never reimage, "factory reset" or discard hardware that was involved.

Copy. Where you export logs or files, make a working copy and keep the original untouched. Where a specialist takes a forensic image, they will usually record a **hash value**, a digital fingerprint, so anyone can later check that the copy has not changed. Guidance on handling digital evidence, such as ISO/IEC 27037, centres on identifying, collecting, acquiring and preserving evidence in a way that keeps its integrity.[5]

Record. For every item, note what it is, where it came from, who took it, when, where it is stored and who has handled it since. This is the **chain of custody**. For a small business it can be a simple table (Appendix D), but filling it in as you go is what turns a pile of files into evidence.

A sealed, labelled box: one item, one record, one custodian

> **Worked example (fictional): Halden & Roe, version one.** On the day, the freelancer reinstalls the main server within hours to get the practice trading. It works. It also erases the system's logs and the evidence of how the attacker got in. The insurer's forensic specialist later reports that the route in "cannot be determined with confidence", which leaves the insurer asking whether the practice's stated security controls were in place. Nobody can prove they were, and nobody can prove they were not.

Personal devices, messaging apps and informal channels

Small teams run incidents through WhatsApp groups and personal phones. That is fine, provided you treat those channels as **records**. Save the group chat or export it at the end of each day, note who was in it, and move key decisions into the decision log. Do not use the compromised email system to discuss the incident: assume the attacker can read it.

When the incident is not ransomware

The same order of operations works for the other common small-business incidents.

- **Business email compromise or invoice fraud:** call your bank immediately to ask for a recall, then the insurer. Keep the fraudulent emails with full headers, the payment instruction, the bank confirmation and any call or verification record. Time matters enormously for recall.

- **Lost or stolen device:** record when it was last seen, what was on it and whether it was encrypted; report to police where appropriate and keep the reference.
- **Mailbox or account takeover:** preserve the login history and rules that were created, such as forwarding rules, before you remove them.
- **Data leak or misdirected email:** keep the original message and the recipient list, and note what personal data was in it.

Chapter checklist

- ☐ The first-hour sequence is printed and a deputy can follow it.
- ☐ A timeline log and decision log are started in the first hour.
- ☐ Every item of evidence has an ID, a source and a custodian.
- ☐ Nothing has been wiped, reimaged or deleted without advice and a forensic image.
- ☐ Messaging-app discussions are saved at the end of each day.

CHAPTER 4

Notifying the Insurer and Meeting Policy Conditions

A sealed envelope and a pen: notice is a formal act, and it should leave a record

Telling your insurer is the moment a cyber incident becomes a cyber claim. It is also where many small businesses lose ground, either by telling them too late or by doing something expensive first. This chapter explains the typical conditions in a cyber policy, the clocks that start running, and how to make notice a clean, provable event.

Notice: when, who and how

Most policies require you to notify "as soon as practicable" or within a fixed number of hours or days of discovering the incident. Some make timely notice a **condition of cover**. Legal systems differ on what happens if you are late. In some places the insurer must show it was harmed by the delay, in others late notice can be fatal without any such showing, and courts have found long unexplained delays to fall outside "as soon as practicable".[1][2] You cannot know in advance which rule would apply to you, so the safe rule is the same everywhere: **tell them early.**

In practice, "early" means:

- **Call the 24-hour incident line first**, before hiring any specialist, wherever your policy provides one. The line exists to start your response and to protect your cover.
- **Follow with a written notice** to the address or portal named in the policy, and copy your broker. A call is not proof; an email is.
- **Notify circumstances**, not just losses. If you suspect an incident but have not yet quantified anything, say so. Many policies allow, and some insurers encourage, a notice of circumstances.
- **Notify even if the loss may be below your excess.** The loss often grows, and an early record protects you.

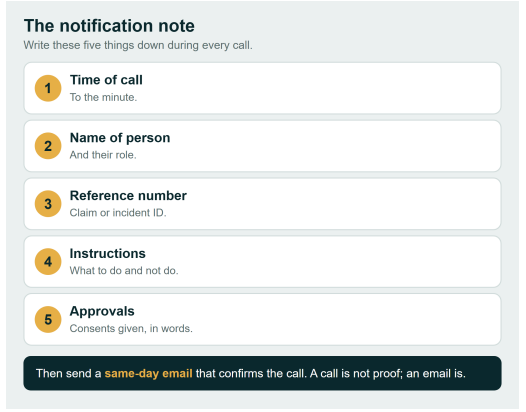
> **The rule.** Notice is cheap and silence is expensive. Report early, report in writing, and keep the proof.

What to say in the first call

You do not need every fact. A first call is about starting the process. Have this ready (Appendix E has a fill-in form):

- policy number, business name and your name and role;
- the date, time and how the incident was discovered;
- a short factual description, labelled as fact or belief;
- what you have done so far, including any containment;
- what you need now: forensic help, legal advice, a ransom or payment question, a bank recall;
- the names and numbers of the people who will liaise.

Write down, during the call: the **time**, the **name of the person you spoke to**, any **claim or reference number**, what they told you to do and not to do, and any approvals. Then send an email the same day summarising it: "Further to our call at 10:25 today with [name], we confirm..." That email turns a conversation into a record.



The notification note: five things to record about every call to the insurer

Typical policy conditions you should know

Cyber policies attach a set of conditions to the cover. Names and detail vary, but these appear again and again.[3]

Notification. Covered above. Check whether notice must go to the insurer, the broker, or both, and whether the policy specifies a method.

Consent before incurring costs. Many policies require you to obtain the insurer's prior written consent before you spend money on investigation, legal fees, ransom, public relations or other response costs. Costs incurred without consent may not be reimbursed, and even where consent is given, the insurer may agree only the rates its panel has negotiated.[1]

Panel vendors. Some policies require you to use the insurer's panel of lawyers, forensic firms and others. Using a non-panel vendor without approval can mean the cost is not repaid. If you have a trusted IT provider, ask **in advance** whether they can be approved, and what role they may play.

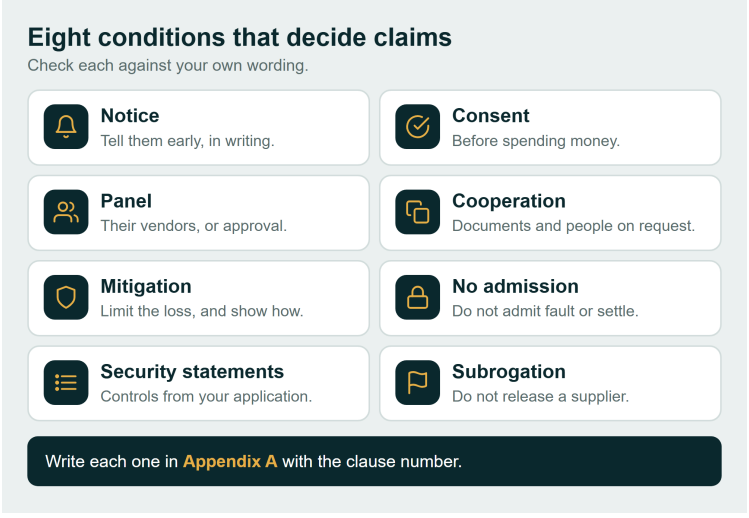
Cooperation. You must provide information and documents the insurer reasonably requests, make employees available and help investigate. Slow or partial responses can delay or reduce payment.

Duty to mitigate. You must take reasonable steps to limit the loss. Document what you did and why, because "reasonable" is judged afterwards.

No admission of liability or settlement. Do not admit fault, agree compensation or settle a claim with a customer, regulator or attacker without the insurer's agreement. A friendly apology to a client can be treated as an admission, so check what you may say.

Security warranties or minimum standards. Statements about your controls in the application, and sometimes continuing obligations such as maintaining backups or MFA. Appendix A asks you to list them.

Subrogation. The insurer may pursue those who caused the loss, such as a negligent supplier. Do not sign a release or waiver without telling the insurer, as it may remove their rights.



Eight policy conditions that most often decide a cyber claim

Exclusions and the evidence they invite

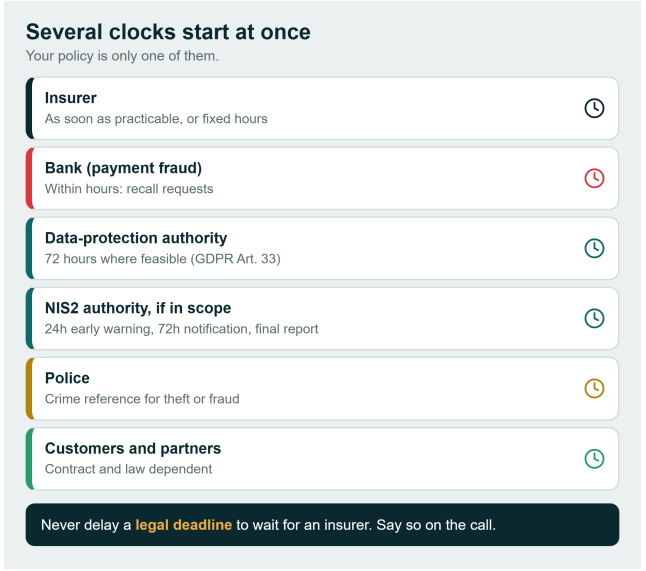
Exclusions are events or losses the policy does not cover. Ones that regularly cause debate include war and state-backed cyber operations (the insurance market tightened these wordings from 2023, and wording differs widely), failure to maintain agreed security, prior known incidents, betterment (the cost of upgrading rather than restoring), and in many places fines and penalties that the law does not allow to be insured.[7] Be aware of them. Do not try to argue them in your first notice. Your job at that stage is to give the insurer **accurate facts and a clean record**, and to leave the interpretation of exclusions to the people who are qualified to do it.

Parallel clocks: other people you may have to tell

The insurer is only one of the parties with a deadline. Several clocks may start at once, and they run independently of your policy.

- **Data-protection authority.** Under the GDPR, a controller must notify the supervisory authority of a personal data breach without undue delay and, where feasible, within **72 hours** of becoming aware of it, unless the breach is unlikely to result in a risk to people. Individuals must be told without undue delay if the risk is high.[4]
- **NIS2 incident reporting.** If your business is in scope of the NIS2 Directive as an essential or important entity, a significant incident triggers an **early warning within 24 hours**, an incident notification within **72 hours** and a final report, generally within one month, though national rules and sector rules differ.[8]
- **Your bank and payment provider.** For payment fraud, a recall request in the first hours can mean the difference between recovering money and not.
- **Police.** A crime reference is often requested by insurers, especially for theft and fraud.
- **Customers, partners and employees.** Contracts and the law may require you to tell them, and what you say should be consistent across all audiences.

You should tell the insurer **before** you notify a regulator or a client where you can, because the insurer's panel lawyers often help with that wording, and because some policies expect to be consulted. But **never delay a legal deadline** to wait for an insurer. If a clock is running, say so on the call and ask for help now.



Several clocks start at once: insurer, regulator, bank and customers

Working with the claims handler

After notice, the insurer assigns a claims handler or loss adjuster. A few habits make the relationship smoother and the file stronger.

- **Use one channel and one voice.** One person on your side communicates with the insurer. Others route questions through them.
- **Put it in writing.** Confirm calls by email. Ask for approvals, consents and positions in writing.
- **Answer fully and on time.** Keep a list of every request and its due date, and your response.
- **Keep copies of everything you send**, including the date, who received it and in what form.
- **Ask for a reservation-of-rights letter to be explained** if you receive one. It means the insurer is investigating and reserves the right to decline in part or in full. It is not a refusal, but it is a signal that your documentation will be scrutinised.

> **Worked example (fictional): Brightline Print.** Brightline discovers the fake invoice on Monday. By 09:30 the owner has phoned the bank for a recall and the insurer's hotline, in that order, and logged both. The bank recovers part of the money. The insurer asks for the email chain, the payment instruction, the date of the last confirmed bank-detail change and the verification call record. Brightline can supply the first three and, honestly, tells the insurer that there was no call. The conversation that follows is uncomfortable but honest. The claim is assessed on the facts, not on an explanation that later falls apart.

If something goes wrong with notice

Perhaps you notified late. Perhaps you hired someone before asking. Do not hide it. Tell the claims handler plainly what happened, when and why, and ask how they would like to proceed. Insurers deal with this regularly, and honesty usually leaves more room for a sensible outcome than discovery later. Then ask your broker and, if the amount is significant, a lawyer who specialises in insurance, because the right advice depends on your policy and your country.

Chapter checklist

- ☐ Hotline called first; time, name and reference recorded.
- ☐ Written notice sent the same day, with the broker copied.
- ☐ Consent obtained in writing before any spending, or an exception recorded.
- ☐ Panel and non-panel vendors confirmed.
- ☐ Parallel deadlines (regulator, bank, police) identified and diarised.
- ☐ Every insurer request logged with a due date and answer.

CHAPTER 5

Business Interruption and Financial Loss Records

An open ledger and a brass calculator: business interruption is proved with ordinary accounting records

For many small firms the largest loss in a cyber incident is not the ransom, the specialist's invoice or the replacement laptop. It is the weeks in which they cannot trade properly. Business interruption (BI) cover is meant to replace that lost income, but it also demands the most from your records, because it asks you to prove what **would have** happened.

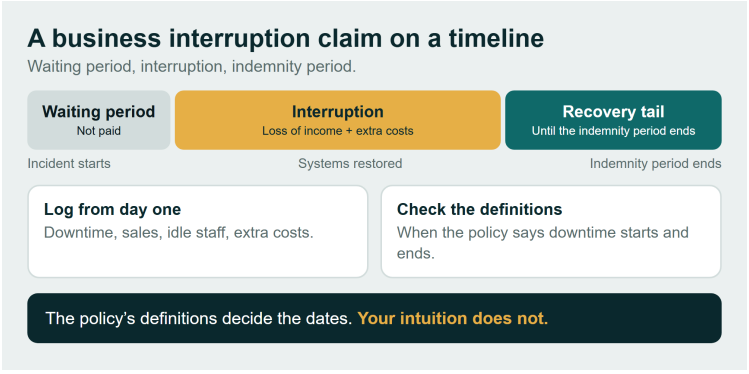
What BI cover usually pays for

Wordings differ. As a rule, BI cover responds to two kinds of loss during the period of interruption.[3]

- **Loss of income:** the gross profit, or net profit plus continuing costs, that you would have earned if the incident had not happened.
- **Increased costs of working:** extra costs to keep going or to reduce the loss, such as overtime, temporary equipment, outsourcing, manual workarounds or rented space.

Some policies add **dependent business interruption**: loss caused by an outage at a supplier or service you rely on. It is usually narrower and sub-limited, and the exact definition of "dependent" matters.

Two time limits shape what can be claimed. The **waiting period** is the initial stretch of downtime, often a number of hours, that is excluded. The **indemnity period** is how long after the incident the policy will pay for lost income. Both start and end according to **the policy's definitions**, not your intuition about when you "felt back to normal".

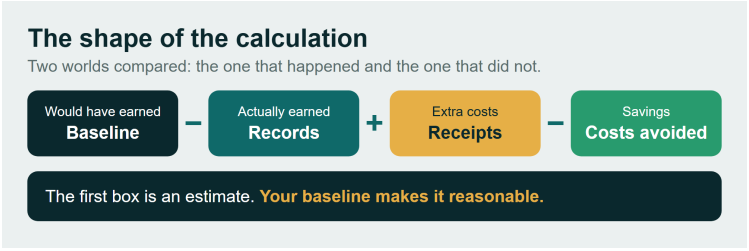


A business interruption claim on a timeline: waiting period, interruption and indemnity period

The question the insurer must answer

At heart, a BI claim compares two worlds: the one that happened and the one that did not.

> **Loss of income = what you would have earned − what you actually earned**, plus **extra costs** you reasonably incurred to reduce the loss, minus **savings** you made as a result of the interruption.



The shape of a business interruption calculation

The "would have earned" side is an estimate, so insurers and their forensic accountants look for **evidence that makes the estimate reasonable**. That evidence is your baseline from Chapter 2 and the records you keep during the interruption.

Records to keep during the interruption

Start these records on day one and keep them daily. It is far easier to write a line a day than to reconstruct a month.

Downtime log. Which systems were unavailable, from when to when, and what that stopped you doing. Note partial working as well as total outage.

Sales and orders. Daily or weekly sales while affected. Orders lost, cancelled, delayed or refunded, with customer and value. Quotes you could not issue. Bookings you could not take.

Staff costs. Hours of staff who could not work because systems were down but whom you continued to pay, with names or roles, rates and dates. Overtime and agency staff used to recover.

Extra costs. Every receipt and invoice for temporary solutions: hired laptops, mobile data, courier costs, manual processing, additional accounting time, rented space. Note why each cost was necessary.

Continuing expenses. Rent, salaries, loan payments and other costs that continued during the outage, with proof.

Customer impact. Complaints, credits, discounts or compensation you gave, and the reason, noting that you should check the policy before promising anything.

Mitigation steps. What you did to limit the loss: phone orders, manual invoices, alternative suppliers. This evidences your duty to mitigate.

Normal, trend and seasonality

A fair "would have earned" figure respects reality. If your business grows 10 percent a year, flat prior-year figures understate it. If it is seasonal, a quiet month compared to a busy one overstates the loss. Good records let a specialist adjust for:

- **Trend:** growth or decline in the months before the incident.
- **Seasonality:** the pattern across the year.
- **One-off events:** a big contract or a closure that will not repeat.
- **Known changes:** a new product, a price rise, a lost client.

If you keep a forecast or budget, keep the version that existed **before** the incident, because an after-the-fact forecast looks like advocacy.

Costs to restore versus costs to improve

Insurers pay to put you back where you were, not to give you something better. If you replace an old server with a bigger one, or add security tools you did not have, expect questions about the **betterment** element. Ask the specialist or supplier to **separate like-for-like restoration costs from upgrades** on the invoice, and get the insurer's view before the work is done where you can.

Avoiding double counting and overclaiming

Honesty and accuracy are not just ethics here. They are legal risk. In most places an intentionally exaggerated or fabricated claim is **insurance fraud**, with consequences far beyond losing the claim.

Check for double counting: staff wages counted both as continuing costs and as extra costs; lost sales counted again as refunds; a specialist's fee in both the response-cost and the loss-of-income calculations. Mark estimates as **estimates**, explain how they were made, and be ready to show the working. A small, well-supported claim is worth more than a large one that unravels.

Social-engineering and funds-transfer losses

These are not BI claims but depend on similar discipline. For a payment-fraud loss, assemble: the fraudulent message with headers; the payment instruction and approval trail; bank statements and recall correspondence; your verification procedure and the record of whether it was followed; the date and method of discovery; police report. Because policy conditions for these losses are often strict, and caps low, the verification record can matter as much as the invoice itself.

> **Worked example (fictional): Halden & Roe, version two.** After the ransomware attack, the practice's systems are partly down for 11 working days. Ines keeps a one-page log each evening: systems affected, staff idle, invoices delayed, extra costs. At the end, the forensic accountant uses the 36-month baseline to show that March and April fees normally run 18 percent above the annual average, which makes the loss larger than a flat-month comparison would suggest. Because the numbers are documented, the discussion is about the method, not about whether the practice is making the figures up.

Use a worksheet and a specialist

Appendix F gives a simple loss worksheet. For larger or more complex losses, ask the insurer whether it will appoint, or accept, a **forensic accountant**. Many policies cover the reasonable cost of preparing the claim. Agree who instructs them, and what information they will need, before they begin.

Chapter checklist

- ☐ The waiting period and indemnity period are known and their start and end are logged.
- ☐ A daily downtime, sales and staff-idle record is kept from day one.
- ☐ Extra costs are receipted and explained.
- ☐ A pre-incident baseline and forecast are saved, unchanged.
- ☐ Upgrades are separated from like-for-like restoration.
- ☐ Every estimate is labelled and every double count removed.

CHAPTER 6

Working with Forensic, Legal and Other Specialists

A magnifying glass over a circuit board: specialists find facts, and your records make those facts usable

A small business rarely has the skills to investigate an incident, advise on regulatory duties and calculate a loss at the same time. The insurer's panel exists to supply them. But specialists are only as good as the information and instructions they are given, and **how** they are engaged affects both your claim and who can see their work. This chapter explains who does what, and what to record.

The cast

Your broker knows your policy and the market. They are your first adviser on the policy, the person who can chase the insurer and often the one who can tell you what is normal.

The insurer's claims handler or loss adjuster decides what is covered and how much is paid. They are not your adviser. They are courteous and necessary, but their interest is not identical to yours.

Breach or incident counsel is a lawyer, often from the panel, who advises on legal duties: notifying regulators and individuals, contracts, liability, communications and, where appropriate, how to commission other specialists. In many incidents they coordinate the response.

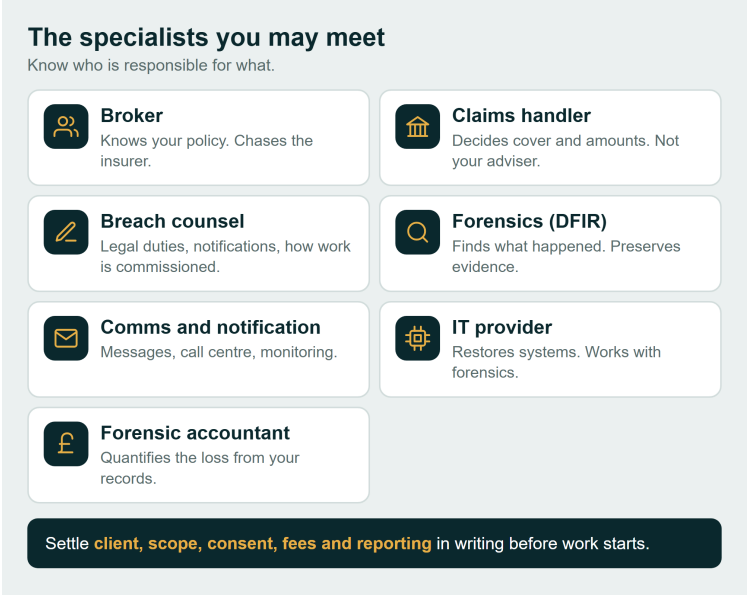
Digital forensics and incident response (DFIR) investigates what happened: how the attacker got in, what they touched, whether data left, and whether systems are safe to restore. They preserve evidence and produce the technical findings.

Negotiators and cryptocurrency specialists may appear in extortion cases. They act only with the insurer's and counsel's involvement, because paying an attacker has legal and sanctions implications.

Communications and notification providers draft customer and staff messages, run call centres and offer credit or identity monitoring where appropriate.

Your IT provider or staff restore systems, working with the forensic team so that evidence is not lost.

A forensic accountant quantifies the financial loss, using the records from Chapter 5.



The specialists you may meet, and what each is responsible for

Questions to settle before anyone starts

Before a specialist begins, get these in writing: a short email is enough.

- **Who is the client?** The business, the insurer or the law firm? This affects confidentiality, reporting and costs.
- **Is the insurer's consent in place?** Cost approval, rates and scope.
- **What is the scope?** The questions to be answered, the systems to be examined, the deliverables and the deadline.
- **What are the fees?** Hourly rates, estimates, expenses and who pays whom. Request itemised invoices from the start.
- **Who will see the work?** Who may receive reports, in what form, and whether anything is to be kept confidential.
- **How will evidence be handled?** Imaging, hashing, storage and chain of custody.

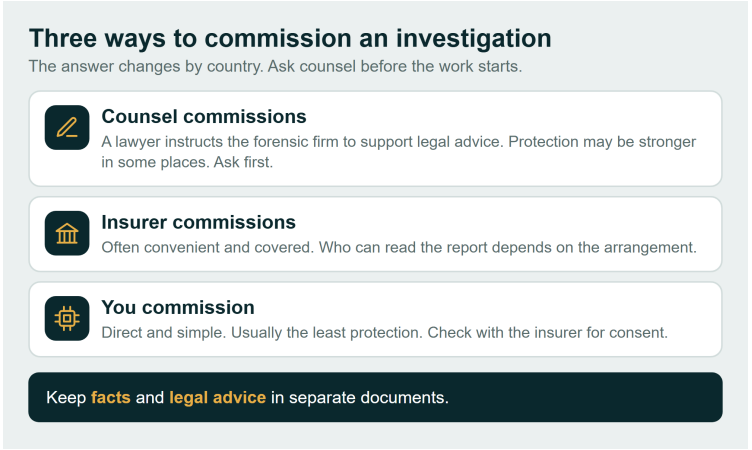
> **The rule.** Do not let anyone start billable work until the client, scope, cost consent and reporting line are written down.

Privilege, reports and who commissions what

Whether an investigation report can later be demanded by a regulator, a claimant or a court depends on the country, on who commissioned the work and on its purpose. In some systems, work done at the direction of a lawyer for the purpose of legal advice may be protected by privilege; in others, protection is narrower, and in the EU the position of in-house lawyers is limited. The outcome in a particular case is not something this book can predict.[2]

The practical lessons are modest and safe:

- **Ask counsel before commissioning**, not after. Who instructs the forensic firm can change who can read its report.
- **Keep factual and legal advice distinct.** Ask whether a short factual summary can be given to the insurer and regulators separately from advice you want to keep confidential.
- **Be careful what you write.** Speculative comments in emails and chat ("we were careless", "this was our fault") are records too.
- **Do not circulate reports widely.** Share them on a need-to-know basis, and log who received what.



Three ways a forensic investigation can be commissioned, and the questions each raises

What to ask a forensic examiner to deliver

A good forensic report supports your claim, your regulatory notifications and your recovery. Ask for:

- **A dated timeline**, from initial access to discovery and containment.
- **Root cause and entry point**, with the level of confidence, and what could not be determined.
- **Scope of impact:** systems affected, data accessed or taken, accounts compromised.
- **Whether personal data was involved**, in what volume and categories, because that drives GDPR duties.
- **Evidence handling record:** what was collected and how it is stored.
- **Remediation steps and confirmation of containment**, kept distinct from upgrade recommendations (for betterment).
- **An executive summary** you can share, in plain language.

Check that the report's facts match **your** timeline. Where they do not, ask why, and correct whichever is wrong in writing. Contradictions are what disputes feed on.

Keeping the specialist and cost log

Appendix G is a running log of every specialist engaged: name, role, engaged by whom, date, consent reference, rate, deliverables and invoices. Update it weekly. When the claim is assembled, this log lets the insurer and you reconcile what was spent, approved and paid, and protects you against a bill that nobody remembers authorising.

Your own staff and IT provider

Do not leave out the people already helping. Record who from your team worked on the incident, for how long and on which tasks. Where the IT provider does recovery work, get a written scope, hours and rates, and ask whether the insurer will reimburse it or treat it as normal operating cost. Some policies reimburse internal costs only in particular circumstances, so ask early.

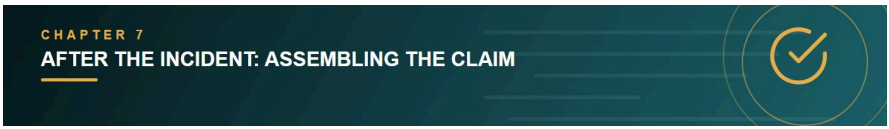
> **Worked example (fictional): Halden & Roe, version two.** The insurer's hotline puts the practice in touch with breach counsel and a forensic firm within two hours. Counsel sends a short engagement letter; the forensic firm agrees a scope, an hourly estimate and imaging of the file server and two laptops before restoration begins. Ines files both letters in the folder and logs the consent reference. The freelancer is told to hold any rebuild until imaging is done and is paid by the practice, with the insurer's agreement to treat the like-for-like part as a claim cost.

Chapter checklist

- ☐ Client, scope, consent, fees and reporting written down for each specialist.
- ☐ Counsel asked how the forensic work should be commissioned.
- ☐ The required report contents agreed.
- ☐ Specialist and cost log updated weekly.
- ☐ Internal and IT-provider time recorded with a written scope.

CHAPTER 7

After the Incident: Assembling and Submitting the Claim



A watch on dark leather: the weeks after an incident are when claims are won through patience and order

When the systems are back and the adrenaline fades, the claim begins in earnest. The work in this chapter is administrative, which is its strength: if you have kept the records in the earlier chapters, you are mostly **collecting and indexing**, not creating from scratch.

Find the claim requirements

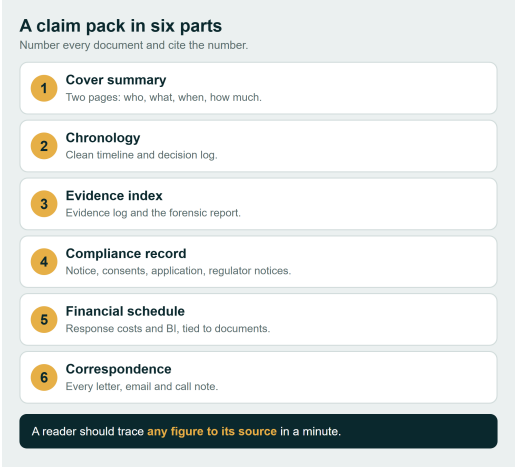
Read what the policy and the insurer's letters say about the claim itself. Look for:

- **A proof-of-loss or claim form,** and the deadline for returning it.
- **A required level of detail:** receipts, calculations, statements, reports, sometimes a declaration or sworn statement.
- **Interim payments:** whether the insurer will pay in stages for response costs or BI.
- **Time limits:** for submitting the claim, for supplying further information and, in the policy or by law, for starting any legal proceedings.
- **Who else must sign:** for example, a director or owner.

Diarise every date. If a deadline looks impossible, ask for an extension **in writing, before it passes**.

Assemble the claim pack

The claim pack is the index to the file you have been building. A simple structure works for most small claims.



A claim pack in six parts

1. **Cover summary.** Two pages: who you are, the policy, what happened, when you notified, the amounts claimed by category, and the contents.
2. **Chronology.** A clean copy of the incident timeline and decision log, with sources, tidied for readability but not altered. Keep the original too.
3. **Evidence index.** The evidence log, with a reference for each document, and the forensic report or summary.
4. **Compliance record.** Proof of notice, consents obtained, the controls claimed in the application with their dated evidence, and regulatory notifications.
5. **Financial schedule.** Response costs, business interruption and other losses, in categories, each tied to documents.
6. **Correspondence.** Letters, emails and call notes with the insurer, broker and specialists.

Appendix H is a one-page index to fill in. Number each document and refer to the number in the schedules, so that a reader can trace any figure to its source in a minute.

Reconcile before you submit

A claim fails on small inconsistencies as often as on big ones. Before sending:

- **Dates agree** across timeline, forensic report, notification record and invoices.
- **Amounts agree** between the schedule, the receipts and the bank records.
- **Every cost has a consent reference** or an explanation.
- **Estimates are marked** and explained.
- **No double counting** across response costs and BI.
- **Personal items are removed.** Do not mix personal spending into the claim.
- **Privileged or sensitive material** is reviewed by counsel before disclosure.

Ask a second person to read the pack with a fresh eye and a single question: "Could I follow this without having been there?"

Submit and track

Send the claim by the method the insurer specifies, keep proof of sending, and record what you sent and when. Then:

- **Chase politely and in writing,** referring to the claim number.
- **Answer questions in full,** one answer per question, with document references.
- **Record every conversation** in the correspondence file.
- **Ask for the reasons** if the insurer proposes to pay less, to delay or to decline, and ask which policy provisions it relies on.

If the insurer disputes the claim

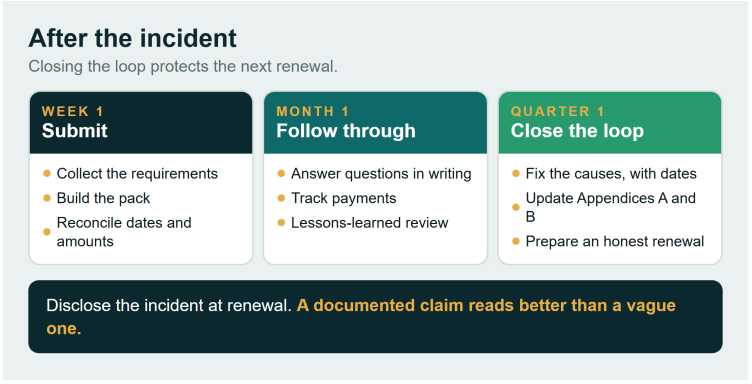
Not every claim is paid in full or at once. Disagreements are common over the amount of business interruption, over betterment, over late notice and over whether a security condition was met. If it happens to you:

1. **Stay calm and polite.** Keep communicating in writing.
2. **Ask for the position in writing,** with the policy provisions relied on.
3. **Involve your broker,** who may be able to resolve it commercially.
4. **Take specialist advice** for any significant dispute, from a lawyer experienced in insurance.
5. **Check complaint routes.** Many countries offer an insurance complaints scheme or ombudsman for small businesses. Eligibility and rules differ, so ask your broker or adviser rather than assuming.

Do not threaten, exaggerate or alter documents. Your best asset in a dispute is a complete, consistent, honest file.

After the claim: close the loop

The claim file is not finished when the money arrives.



What to do in the week, month and quarter after an incident

- **Keep the file.** Retain the claim file for a period your lawyer or adviser recommends; limitation periods for claims and regulatory action vary by country.

- **Run a lessons-learned review** within a month: what worked, what you could not find, what you will change. Update Appendices A and B accordingly.
- **Fix the causes** of the incident, and record the fix with dates, which will help at renewal.
- **Be open at renewal.** Disclose the incident in your next application. Trying to hide a known incident is the surest way to endanger future cover. A documented, well-handled claim is often viewed more favourably than a vague one.
- **Check your cover for the next time.** Was the limit enough? Was the waiting period right? Were the sub-limits a surprise? Raise it with the broker.

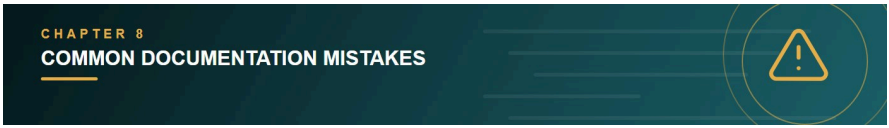
> **Worked example (fictional): Halden & Roe, version two.** Ines submits the claim pack in week five. It is 31 pages: a two-page summary, an 18-entry timeline, the forensic report, a notice record, three consents, a loss schedule with 22 receipts and a BI calculation with a 36-month baseline. The insurer asks four questions and pays the response costs in two stages; it queries 9 percent of the BI figure on the question of an unusually busy prior-year March, which the baseline answers. At renewal, the broker passes the file to the new underwriter alongside the fixes. The premium rises, but cover continues.
>
> **The rule.** Index everything, reconcile everything and keep a copy of everything you send.

Chapter checklist

- ☐ The claim form, deadlines and requirements are diarised.
- ☐ The six-part claim pack is assembled and numbered.
- ☐ Dates, amounts, consents and estimates are reconciled.
- ☐ A second reader has tested the pack.
- ☐ Proof of submission and a response tracker are kept.
- ☐ A lessons-learned review is booked within a month.

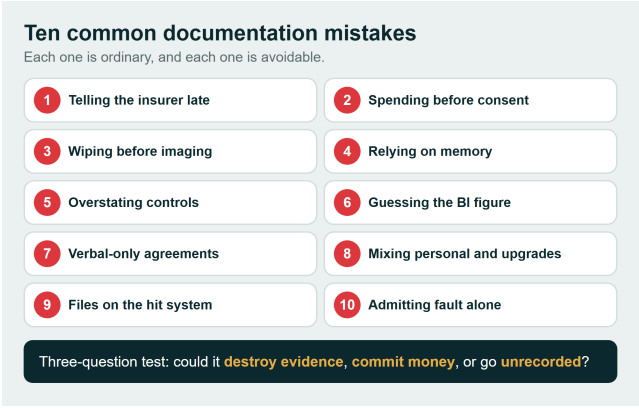
CHAPTER 8

Common Documentation Mistakes



Archive boxes on a steel shelf: the small errors that become big claim problems

Most of the mistakes that damage cyber claims are ordinary human ones, made under stress. Here are ten of the most common, why each hurts and how to avoid it.[1][2]



Ten common documentation mistakes at a glance

1. Telling the insurer late

Why it hurts: Notice conditions are often strict, and a delay can reduce or remove cover depending on the policy and the law. **Do instead:** Call the hotline first, confirm in writing, and notify circumstances early.

2. Spending before consent

Why it hurts: Costs incurred without approval may not be reimbursed, or only at panel rates. **Do instead:** Ask for written consent, record the reference, and keep every receipt.

3. Wiping or rebuilding before imaging

Why it hurts: You destroy the evidence of how the incident happened, which weakens the claim and the regulatory response. **Do instead:** Contain, preserve and image first; rebuild after.

4. Relying on memory

Why it hurts: Recollections drift and contradict each other. **Do instead:** Start the timeline in the first hour and log decisions as they happen.

5. Overstating your security controls

Why it hurts: The application can become the centre of a coverage dispute if what you said does not match what was true. **Do instead:** Keep dated proof, state controls accurately and tell the broker when things change.

6. Guessing the business interruption figure

Why it hurts: An unsupported estimate invites a large reduction and suspicion. **Do instead:** Use a documented baseline, a daily loss log and a reasoned method.

7. Verbal-only agreements

Why it hurts: "They said it was fine" does not prove anything. **Do instead:** Confirm every approval, instruction and call by email.

8. Mixing personal costs, upgrades and unrelated items

Why it hurts: It looks like padding and undermines the rest of the claim. **Do instead:** Separate like-for-like restoration from improvements, and business from personal.

9. Letting the file live on the compromised system

Why it hurts: The records are encrypted, deleted or unreachable when needed most. **Do instead:** Keep copies off-network, including a printed folder.

10. Admitting fault or settling without the insurer

Why it hurts: It may breach the policy and prejudice the insurer's position. **Do instead:** Route claims, settlements and public statements through the agreed process.

> **Worked example (fictional): Brightline Print.** The owner, embarrassed by the fake invoice, drafts an email to the supplier saying "this was entirely our mistake and we will cover your costs". It never goes out, because the office manager reads the policy's no-admission clause first and asks the broker to review the wording. The supplier's cooperation, and the insurer's, are both still intact a week later.

A short test for any action

If you are unsure whether to do something during an incident, ask three questions:

1. **Could it destroy evidence?** If yes, stop and ask.
2. **Will it cost money or commit the business?** If yes, get consent in writing.
3. **Can I show later that I did it, when and why?** If not, write it down now.

Chapter checklist

- ☐ The team has read the ten mistakes.
- ☐ The three-question test is printed in the folder.
- ☐ Copies of the claim file exist off-network.

Conclusion: Show Your Working

A cyber claim is a conversation between two parties who both want it to be settled fairly and quickly, and who both know that the facts are the only thing that can make that happen. You do not control the incident. You do not control the policy wording. You control something just as important: **the quality of your record**.

The habits in this book are small. Keep the policy and the hotline outside your network. Know your excess, your waiting period and your notice clause. Keep dated proof of what you claim to do. Hold your financial baseline. In the first hour, contain, call and write. During the incident, keep a timeline and an evidence log. Get consent before you spend. Keep your records of loss every day. Index it all and hand it over in order. And when you have finished, learn from it.

You will notice that none of this requires technical skill. It requires **discipline**, and the discipline is easier to build on a quiet Tuesday than to improvise on the worst one. If you do one thing after reading this book, fill in Appendix A and put the hotline number somewhere that will not be encrypted. If you do two, hold the 30-minute rehearsal.

The best claim file is the one you never have to use. The second best is the one you are glad you kept.

APPENDIX A

Policy Conditions Checklist

Complete from your own policy wording, schedule and endorsements. Write the page or clause number beside each answer. Review at every renewal.

Insurer: _____ **Policy no.:** _____ **Period:** _____

Broker and mobile: _____

Item	Our policy says	Page / clause
24-hour incident hotline		
Claims email or portal		
Notification deadline and method		
Overall limit		
Excess (retention) per claim		
Business interruption waiting period		
Business interruption indemnity period		
Sub-limit: funds transfer / social engineering		
Sub-limit: cyber extortion		
Sub-limit: dependent business interruption		
Consent needed before costs?		
Panel vendors required?		
Security conditions or warranties		
Exclusions to discuss with broker		
Fines and penalties covered where lawful?		
Proof-of-loss form and deadline		

Questions to put to the broker

- Can our own IT provider be approved as a panel or supporting vendor? _____
- What costs does the insurer treat as betterment? _____
- Are internal staff costs reimbursed? _____
- What exactly counts as "discovery" for notification? _____

APPENDIX B

Pre-Incident Readiness Record

Update quarterly. Keep a printed copy and one off-network.

Claim owner: _____ **Deputy:** _____ **Last reviewed:** _____

- ☐ Policy, schedule, endorsements and application stored in three places (one off-network)
- ☐ Hotline number saved on paper and on staff phones
- ☐ Spending authority written down: up to EUR _____ by _____, above that _____
- ☐ System, service, data and backup list current
- ☐ Dated MFA evidence saved (date: _____)
- ☐ Last backup restore test recorded (date: _____)
- ☐ Patch and endpoint-protection evidence saved
- ☐ 24 to 36 months of profit and sales figures saved off-network
- ☐ Log sources and retention checked
- ☐ One-page first-hour sequence printed
- ☐ 30-minute rehearsal held (date: _____)

Log source	Kept for	Stored where	Who can export
Email / cloud audit			
Firewall / VPN			
Endpoint protection			
Server / file sharing			
Payment / accounting system			

APPENDIX C

Incident Timeline and Decision Log

Start in the first hour. One writer, one clock. Use **Fact**, **Believed** or **Unknown** in the Status column. Time zone: _____

Date and time	What happened	Source	Status	Action taken (who)	Evidence ref

Decision log

Date and time	Decision	Made by	Reason	Insurer consulted?

APPENDIX D

Evidence and Chain-of-Custody Log

One row per item. Record every hand-over. Keep originals untouched and work from copies.

ID	Item and description	Taken from	Date, time, by whom	Hash (if any)	Stored where	Handed to / date
E-001						
E-002						
E-003						
E-004						
E-005						
E-006						

Before you move or change anything, ask:

- ☐ Has a copy or image been taken, and recorded here?
- ☐ Has the insurer or specialist agreed the step?
- ☐ Is the change itself written in the timeline?

APPENDIX E

Insurer Notification Record and Letter

Call record

Item	Details
Date and time of call	
Hotline number used	
Name of person spoken to	
Claim or reference number	
Instructions given (do / do not)	
Approvals or consents given	
Next contact, who and when	

Written notice (adapt and send the same day, copy your broker)

To: [insurer claims address] Cc: [broker] Subject: Notice of cyber incident, policy [number], [business name]

Further to our telephone call at [time] on [date] with [name], we give notice of a cyber incident under policy [number].

On [date] at [time] we discovered [short factual description]. We believe [belief, labelled as such]. We have so far [containment steps taken], and we have not paid any demand, deleted any data or reinstalled any affected system.

We would like [help requested: forensic, legal, other] and we confirm that we will not incur response costs without your consent except where urgent steps are needed to limit loss, which we will tell you about immediately.

Our contact for this matter is [name, role, phone, email]. We will send further information as it becomes available.

[Name, role, business]

APPENDIX F

Business Interruption Loss Worksheet

Use real figures where you have them and mark estimates **(E)**. Attach the source for every line.

Period of interruption: from _____ to _____ **Waiting period ends:** _____ **Indemnity period ends:** _____

Month or week	Expected income (baseline)	Actual income	Shortfall	Notes on trend or seasonality
Total shortfall				

Increased costs of working	Date	Supplier	Why necessary	Amount (EUR)	Consent ref

Adjustments	Amount (EUR)
Savings made during the interruption (deduct)	
Betterment elements removed	
Double counting removed	

Adjustments	Amount (EUR)
Net claimed for business interruption	

Daily log (copy as needed): Date _____ Systems down _____ Staff idle (names or roles and hours) _____ Orders lost or delayed _____ Extra costs today _____

APPENDIX G

Specialist and Cost Log

One row per engagement and per cost. Update weekly.

Specialist and role	Engaged by	Date	Scope agreed	Insurer consent ref	Rate or estimate (EUR)	Invoice no. and amount

Other response costs	Date	Description	Amount (EUR)	Receipt kept	Consent ref

Running totals: Approved _____ Paid by us _____ Reimbursed _____ Outstanding _____

APPENDIX H

Claim Pack Index

Number every document. Refer to these numbers in the schedules.

Part	Document	Ref	Included
1 Cover summary	Two-page summary and contents	1.1	[ ]
2 Chronology	Timeline and decision log	2.1	[ ]
3 Evidence	Evidence log; forensic report or summary	3.1	[ ]
4 Compliance	Notice record and written notice	4.1	[ ]
4 Compliance	Consents and approvals	4.2	[ ]
4 Compliance	Application and dated control evidence	4.3	[ ]
4 Compliance	Regulator and police notifications	4.4	[ ]
5 Financial	Response-cost schedule and receipts	5.1	[ ]
5 Financial	Business interruption worksheet and baseline	5.2	[ ]
5 Financial	Other losses (fraud, replacement)	5.3	[ ]
6 Correspondence	Insurer, broker and specialist correspondence	6.1	[ ]

Final checks

- ☐ Dates and amounts agree across all parts
- ☐ Every cost has a consent reference or an explanation
- ☐ Estimates are marked and explained
- ☐ A second reader has tested the pack
- ☐ Copy retained; proof of sending saved

Glossary

Application (proposal form): The questionnaire you completed to obtain cover. A statement of what you told the insurer.

Betterment: An upgrade beyond restoring what you had; usually not paid for.

Broker: An adviser who arranges and supports your insurance and helps with claims.

Business interruption (BI): Cover for lost income and extra costs while your operations are disrupted by an insured event.

Chain of custody: The record of who held an item of evidence, when, and what they did with it.

Claims-made and reported: A policy basis requiring the claim to be made and reported within the policy period.

Consent: The insurer's agreement, ideally in writing, before you incur a cost or take a step.

Cyber extortion: A demand for money to stop or reverse an attack, such as ransomware.

DFIR: Digital forensics and incident response.

Excess (retention): The amount of a loss you bear before the insurer pays.

Forensic image: A bit-for-bit copy of a drive or system, used so analysis does not alter the original.

Hash: A digital fingerprint that proves a copy has not changed.

Indemnity period: The period after an incident during which lost income is covered.

Notice of circumstances: A notification of an event that might lead to a claim.

Panel: The lawyers, forensic firms and other vendors the insurer has pre-approved.

Proof of loss: The claim form and supporting evidence of what you lost.

Rescission: Cancellation of a contract from the beginning, which in some places is a remedy for material misrepresentation.

Reservation of rights: A letter in which the insurer investigates while keeping the right to decline in whole or part.

Sub-limit: A lower cap within the overall limit for a specific type of loss.

Subrogation: The insurer's right to recover what it paid from whoever caused the loss.

Waiting period: The initial period of downtime excluded from business interruption cover.

A Note on GDPRGard.eu

GDPRGard publishes free tools, guides and articles to help small businesses understand data-protection duties in plain English, including how to respond to a personal data breach, map data and review processors. Visit **gdprgard.eu** for current guidance, templates and updates on the topics in this book, such as the 72-hour breach notification clock.

About the Author

Zirlandia Milkovic writes practical, plain-English guides on data protection, cyber-security, AI and building a business with confidence. She believes technology should give small businesses more control, not less, and that nobody should need a technical degree to understand their rights or protect their customers.

She is the author of a series of business guides, including *GDPR Made Simple for Women Founders*, and her work focuses on turning complex rules and fast-moving technology into simple steps, checklists and templates that busy people can actually use. She is also behind **GDPRGard**, a growing collection of free GDPR tools, guides and articles for small businesses, available at gdprgard.eu.

The Cyber Claim File grew out of a simple observation: businesses buy cyber insurance and almost never prepare to prove a claim. If this guide helped you, an honest review where you bought it helps other readers find it.

Visit **gdprgard.eu** for free tools, articles and updates.

Notes and Sources

Research cut-off: 12 November 2026. Items marked (read) were opened directly; others were seen through search summaries or secondary coverage, or rest on the author's working knowledge, and should be checked against the original before you rely on them.

1. Lockton, *Cyber Claims Guide* 2022, and Reed Smith, "Pressure points in cyber insurance policies revealed in litigation" (2023): late notice, panel vendors and consent to costs as recurring causes of disputed claims; courts differ on whether the insurer must show prejudice (search summaries only; the documents were not read in full).
2. Reed Smith, "Best practices for avoiding notification disputes in cyber liability insurance" (2023), and related commentary: timely written notice, notice of circumstances, hotline first; commentary on privilege and commissioning of forensic work (search summaries only).
3. General structure of small-business cyber policies (first-party, third-party, incident-response services, sub-limits, waiting and indemnity periods, consent and panel conditions): Lockton *Cyber Claims Guide* 2022 and Aon, *E&O and Cyber Market Review*, coverage considerations (search summaries and working knowledge; not a reading of any specific policy).
4. Regulation (EU) 2016/679 (GDPR), Articles 30, 33 and 34: breach notification to the supervisory authority without undue delay and, where feasible, within 72 hours of awareness; communication to individuals where the risk is high (working knowledge; read the text).
5. ISO/IEC 27037:2012, *Guidelines for identification, collection, acquisition and preservation of digital evidence*: identification, collection, acquisition and preservation of digital evidence, integrity and documentation (summaries only; the standard itself was not read).
6. *Travelers Property Casualty Co. of America v. International Control Services, Inc.*, No. 22-cv-2145 (C.D. Ill.), 2022: insurer's suit to rescind a cyber policy over alleged misstatements about multi-factor authentication in the application; ended with a stipulated rescission (Insurance Journal, Reed Smith and Lockton commentary; the court order was not read, and the terms of the agreement are unconfirmed).
7. Lloyd's Market Association and Lloyd's bulletins on war and state-backed cyber-attack exclusions for cyber policies, applying from 2023 (working knowledge; not verified); insurability of fines and penalties depends on national law and policy wording (working knowledge).

8. Directive (EU) 2022/2555 (NIS2), Article 23: early warning within 24 hours, incident notification within 72 hours, final report generally within one month, with national transposition and sector rules (search summaries only; sources disagree on the starting point of the one-month period, so check the text and your national rules).

Not verified by the author: the wording of any particular policy; how any insurer, court or ombudsman would treat late notice, consent or application statements in a given country; the current detail of the Lloyd's exclusion wordings; whether, where and when privilege would protect a forensic report; limitation periods for claims; and the notification rules that apply to your own sector and country. Halden & Roe and Brightline Print, their people and their figures are fictional.